

Black Book Web Application Execution Beads

1. Target architecture

Build a TypeScript and Python monorepo with the following deployable surfaces:

```
apps/  
  web/                Public Next.js application  
  admin/              Private Next.js administration and research console  
  api-public/         Public read/search/location API  
  api-submissions/    Corrections and future contribution intake API  
  api-internal/       Publication, promotion, and internal control API  
  
workers/  
  research/           Python source discovery and ingestion workers  
  publication/        Projection, snapshot, indexing, and release workers  
  security/           Quarantine, source validation, and integrity workers  
  
packages/  
  ui/  
  domain/  
  schemas/  
  firebase/  
  data-access/  
  security/  
  observability/  
  testing/  
  config/  
  
infra/  
  firebase/  
  gcp/  
  github/  
  database/
```

Use:

- Next.js and TypeScript for public and administrative applications.
- Firebase App Hosting for the public web application.
- Cloud Run for APIs and the private administration application.
- Firebase Authentication for administrators and future trusted contributors.
- Firebase App Check with reCAPTCHA Enterprise.
- Cloud SQL PostgreSQL with PostGIS.
- Firebase SQL Connect for typed application operations.

- Direct, least-privilege PostgreSQL connections for approved Python jobs.
- Firebase Storage and Google Cloud Storage for approved media, evidence, exports, and quarantine.
- Cloud Armor, global external Application Load Balancing, and Cloud CDN.
- Cloud Tasks for bounded asynchronous operations.
- Cloud Run Jobs for research and batch processing.
- GitHub Actions for validation, deployment, migrations, and release promotion.
- GitHub OIDC and Google Workload Identity Federation.
- OpenTelemetry and Sentry.
- PostgreSQL full-text search, `pg_trgm`, and PostGIS before adding another search platform.

2. Non-negotiable system invariants

1. Anonymous users never write to canonical historical data.
2. Public clients never connect directly to canonical database tables.
3. A submission can never become public without passing the promotion workflow.
4. Research workers cannot publish.
5. LLMs cannot publish or approve their own claims.
6. Public rendering never invokes an LLM.
7. Public pages read only released publication projections or immutable snapshots.
8. Living residential addresses are never stored as ordinary person-location fields or publicly returned.
9. Unknown living status is treated as living.
10. External URLs and files are untrusted.
11. Submitted URLs are not synchronously fetched during a user request.
12. Public API database credentials have read-only access to the public schema.
13. Research credentials cannot modify public projections.
14. Publication credentials cannot modify raw evidence.
15. Every public fact maps to accepted claim and evidence records.
16. All publication and retraction decisions are auditable.
17. Every queue, worker, API, and model provider has a bounded concurrency and cost limit.
18. The application supports an immediate read-only degraded mode.
19. Production deployment requires passing security, test, migration, and rollback checks.
20. No feature should require mobile-specific assumptions. Shared contracts must remain portable to Expo later.

Epic A: Product constitution, architecture, and repository foundation

BB-001: Repository reconnaissance and implementation baseline

Priority: P0

Size: M

Dependencies: None

Deliver:

- Inspect the full repository, branches, package managers, Firebase configuration, GitHub workflows, application code, infrastructure, tests, linting, and documentation.
- Identify reusable code and conflicting architectural decisions.
- Produce a repository map and implementation gap report.
- Record exact commands needed to install, test, build, emulate, and deploy.
- Do not rewrite functioning infrastructure without showing why it conflicts with the target architecture.

Acceptance:

- Current state and target state are mapped.
- All build and test commands have been executed or failures documented.
- Existing Firebase and GitHub integration is understood.
- Subsequent beads are adjusted for the actual repository without weakening their requirements.

BB-002: Architecture decision records

Priority: P0

Size: M

Dependencies: BB-001

Deliver ADRs for:

- Firebase App Hosting versus separate Cloud Run services.
- Cloud SQL PostgreSQL and PostGIS.
- Firebase SQL Connect usage boundaries.
- Public projection and immutable publication snapshot model.
- Public, submissions, internal, and admin service separation.
- GitHub Actions deployment model.
- Background workflow model.
- Search and geocoding.
- Research isolation.
- Security and abuse assumptions.

Acceptance:

- Each ADR includes context, decision, rejected alternatives, consequences, migration triggers, and rollback considerations.
- ADRs match implemented code and infrastructure.
- No ADR proposes microservices beyond the explicitly separated security boundaries.

BB-003: Machine-readable product constitution

Priority: P0

Size: M

Dependencies: BB-001

Deliver:

- Encode relevance thresholds, claim confidence thresholds, legal-status vocabulary, record maturity states, public precision rules, source classifications, publication restrictions, and living-person rules in versioned configuration.
- Provide TypeScript and Python loaders generated from one schema.
- Include fixtures for included, excluded, disputed, sparse, sensitive, and living-person records.

Acceptance:

- Policy values are not duplicated across applications.
- Every evaluation records the policy version used.
- Tests fail when unsupported procedural language or prohibited location precision is introduced.
- Policy configuration cannot be changed through a public endpoint.

BB-004: Threat model and abuse-case corpus

Priority: P0

Size: L

Dependencies: BB-001, BB-003

Deliver:

Create a threat model covering:

- Volumetric and application-layer denial of service.
- Cache-busting and expensive search attacks.
- Credential stuffing and administrator phishing.
- Broken object and function-level authorization.
- Spam and coordinated correction brigading.
- Historical misinformation and source laundering.
- Data poisoning through submissions and scraped sources.
- Malicious URLs, SSRF, redirects, DNS rebinding, and oversized responses.
- Malicious file uploads.
- Prompt injection inside researched documents.
- Dependency, GitHub Action, and CI supply-chain compromise.
- Secret leakage.
- Database exhaustion and connection starvation.
- Cloud bill exhaustion.
- Privacy attacks and attempts to expose living addresses.
- Defacement and unauthorized publication.

- Insider mistakes and accidental publication.
- Source adapter drift.
- Search scraping and corpus extraction.

Acceptance:

- Every threat has preventive, detective, containment, and recovery controls.
- Each P0 threat maps to one or more implementation beads.
- Abuse cases become automated or manual security tests.
- Residual risk is explicitly documented.

BB-005: Environment and project isolation

Priority: P0

Size: L

Dependencies: BB-002, BB-004

Deliver:

- Separate Firebase/GCP projects for development, staging, and production.
- Separate production research workloads from public serving workloads, preferably in a dedicated research project.
- Dedicated service accounts for web runtime, public API, submissions API, admin, migrations, research, publication, backup, and GitHub deployment.
- Distinct Storage buckets for public media, private evidence, exports, and quarantine.
- Environment-specific `apphosting` configuration.
- Explicit cross-project access only where required.

Acceptance:

- Development credentials cannot access production.
- Research workers cannot publish.
- Public services cannot read private evidence blobs.
- Quarantine objects cannot be served publicly.
- Compromise of the submissions service does not grant canonical or publication permissions.

BB-006: Monorepo and shared package foundation

Priority: P0

Size: L

Dependencies: BB-001, BB-002

Deliver:

- Workspace-based monorepo with deterministic lockfile.
- Shared TypeScript configuration, lint rules, formatting, environment validation, logging, error handling, and test utilities.

- Separate deployable application boundaries.
- Python workspace with locked dependencies and reproducible local environment.
- One-command local bootstrap.
- Firebase Emulator Suite support where applicable.
- Local PostgreSQL/PostGIS development container.

Acceptance:

- Fresh clone to running local environment is documented and automated.
- Each application builds independently.
- Shared packages cannot import deployable applications.
- Circular dependencies are detected in CI.
- Production environment variables are never required for local tests.

BB-007: Black Book design system

Priority: P0

Size: M

Dependencies: BB-006

Deliver:

- Black and white primary color system with neutral grays.
- Light and dark themes.
- Status colors reserved for warnings, confidence, disputes, and errors.
- Typography pairing with a modern editorial face and restrained technical or monospace face.
- Grid, spacing, elevation, border, icon, motion, focus, and data-visualization tokens.
- Accessible components for cards, citations, confidence, timelines, maps, result lists, filters, dialogs, notices, and empty states.
- Avoid generic neon cyberpunk styling.

Acceptance:

- WCAG contrast requirements are met.
- Keyboard focus is always visible.
- Motion respects reduced-motion preferences.
- Components work at mobile, tablet, and desktop widths.
- Storybook or equivalent component fixtures cover all important states.

BB-008: Automated quality and test foundation

Priority: P0

Size: M

Dependencies: BB-006

Deliver:

- Unit, integration, contract, end-to-end, accessibility, migration, and security test layers.
- Test data builders for entities, claims, evidence, sources, publication releases, and submissions.
- Coverage reporting.
- Deterministic clocks and identifiers in tests.
- CI sharding where useful.
- Emulator-backed Firebase tests.
- PostgreSQL integration tests against disposable databases.

Acceptance:

- Pull requests run the appropriate test suite.
- Tests cannot access production services.
- Flaky tests are quarantined with an owner and deadline, not silently retried forever.
- Required checks are named consistently for GitHub rulesets.

BB-009: GitHub repository governance

Priority: P0

Size: M

Dependencies: BB-001, BB-008

Deliver:

- GitHub ruleset for `main`.
- Pull request required for all changes.
- Required status checks.
- Block force pushes and branch deletion.
- Require resolved conversations.
- CODEOWNERS for security, infrastructure, policies, database, and publication code.
- Dependabot alerts and updates.
- Secret scanning and push protection where plan support permits.
- Limit allowed GitHub Actions to approved publishers or pinned actions.
- Security policy and private vulnerability reporting instructions.

Acceptance:

- Production cannot be deployed from an unreviewed branch.
- Workflow permissions default to read-only.
- Third-party actions are pinned to immutable commit SHAs.
- No workflow uses `pull_request_target` with untrusted checkout and secrets.
- Branch protection is verified through an automated repository policy check.

BB-010: GitHub OIDC deployment identities

Priority: P0

Size: M

Dependencies: BB-005, BB-009

Deliver:

- Google Workload Identity Federation for GitHub Actions.
- Trust conditions bound to numeric repository ID, owner ID, branch, workflow, and protected GitHub environment.
- Dedicated deployment identities for staging and production.
- No long-lived Google service-account keys in GitHub.
- Least-privilege deployment roles.
- Deployment provenance written to release metadata.

Acceptance:

- Unauthorized branches cannot obtain production credentials.
 - Forked pull requests cannot access deployment credentials.
 - Production deployment requires the protected production environment.
 - Credential lifetime is short and credentials are generated per job.
 - Existing JSON service-account secrets are removed after migration.
-

Epic B: Firebase, database, and evidence architecture

BB-011: Firebase project bootstrap

Priority: P0

Size: M

Dependencies: BB-005, BB-006

Deliver:

- Firebase project aliases for development, staging, and production.
- App Hosting backends.
- Authentication configuration.
- App Check applications.
- Storage buckets and rules.
- Emulator configuration.
- Environment-specific configuration files.
- Secret Manager references.

- Minimal Firebase IAM roles.

Acceptance:

- Firebase configuration is reproducible.
- Staging and production cannot accidentally share resources.
- Local development uses emulators or local equivalents.
- Security rules are tested in CI.

BB-012: Cloud SQL PostgreSQL, PostGIS, and SQL Connect

Priority: P0

Size: L

Dependencies: BB-005, BB-011

Deliver:

- Cloud SQL PostgreSQL for each environment.
- PostGIS and required PostgreSQL extensions.
- Firebase SQL Connect service and connectors.
- Generated server-side TypeScript SDK.
- Private connectivity for trusted runtime services.
- Connection pooling.
- Database statement, lock, and idle transaction timeouts.
- Separate database roles for public reads, submissions, admin, research, publication, migrations, and backups.

Acceptance:

- No public browser receives database credentials.
- Every deployable SQL Connect operation has explicit authorization.
- Public API role can read only approved public schemas or views.
- Research role cannot modify canonical or public schemas.
- Publication role can write projections but cannot alter raw evidence.
- Database connection exhaustion tests pass.

BB-013: Database schema boundaries and migrations

Priority: P0

Size: L

Dependencies: BB-012

Deliver schemas such as:

policy
research

canonical
evidence
publication
public
submissions
audit
operations

Implement:

- Transactional migrations.
- Extension and index migrations.
- Migration validation and rollback plans.
- Schema checksums.
- Forward-compatible deployment sequence.
- Seed fixtures for local and test environments.

Acceptance:

- Every table has an explicit owner and access model.
- Public database roles cannot access research or evidence schemas.
- Migrations run against a disposable database in CI.
- Destructive migrations require a migration plan and backup checkpoint.
- Production migration and application rollout order is safe.

BB-014: Entity and geography domain model

Priority: P0

Size: L

Dependencies: BB-003, BB-013

Deliver:

- Entities, aliases, identifiers, types, and relationships.
- Places, geometries, historical boundaries, jurisdictions, and precision.
- Schools, names, campuses, and status history.
- People, organizations, events, laws, cases, publications, artifacts, and institutions.
- Temporal and geographic relationship contexts.
- Duplicate and merge lineage.

Acceptance:

- Historical and current locations can coexist.
- ZIP code is represented as an input or modern geography, not a permanent historical boundary.
- Entity merges are reversible and audited.
- Relationships include evidence and time context.
- Geographic matches record their method and precision.

BB-015: Living-person and sensitive-location enforcement

Priority: P0

Size: L

Dependencies: BB-003, BB-014

Deliver:

- Living-status states including unknown.
- Evidence, internal, and public precision fields.
- Sensitivity classes.
- Precision-reduction reasons.
- Central redaction and serialization layer.
- Tests preventing living residential addresses from APIs, logs, search indexes, models, exports, and maps.
- Occupied private-residence handling for deceased people.

Acceptance:

- Unknown living status behaves as living.
- Public serializers cannot return prohibited precision.
- Searches cannot match prohibited address fields.
- Logs and error telemetry redact protected values.
- Regression fixtures prove that a stored exact address is reduced before publication.

BB-016: Sources, captures, rights, and provenance model

Priority: P0

Size: L

Dependencies: BB-013

Deliver:

- Source organizations and domains.
- Source policies and rights.
- Source items, captures, retrieval events, hashes, and parser versions.
- Stable identifiers.
- Evidence locations, pages, timestamps, and excerpts.
- Publication permissions and prohibited uses.
- Evidence lineage and syndication relationships.
- Source kill switches.

Acceptance:

- Every evidence record resolves to a source item.
- Rights status is required before publication of media or substantial excerpts.
- Source snapshots are selective rather than automatic.

- Duplicate captures are hash-deduplicated.
- A disabled source adapter cannot create new candidates.

BB-017: Claims, contradictions, and confidence model

Priority: P0

Size: L

Dependencies: BB-003, BB-014, BB-016

Deliver:

- Atomic claims and versions.
- Claim temporal and geographic context.
- Claim-to-evidence relationships.
- Supporting, contradicting, and contextual evidence.
- Confidence components.
- Research coverage.
- Relevance and connection-strength measurements.
- Procedural status.
- Publication thresholds by claim class.

Acceptance:

- Confidence is calculated by deterministic code.
- A narrative cannot cite an unpublished claim.
- Contradictory credible values are preserved.
- High-impact claims use their higher threshold.
- Confidence scores retain component values and policy version.
- Repeated syndicated reporting counts as one lineage.

BB-018: Append-only audit and transactional outbox

Priority: P0

Size: M

Dependencies: BB-013, BB-017

Deliver:

- Append-only audit events for policy, source, research, moderation, publication, correction, retraction, authentication, and administrative actions.
- Transactional outbox.
- Idempotency keys.
- Event consumers with retry and dead-letter behavior.
- Actor, reason, request, release, and correlation identifiers.

Acceptance:

- Important state changes and their audit event commit atomically.
- Replayed events do not duplicate effects.
- Audit events cannot be changed through application code.
- An entity's complete publication history can be reconstructed.

BB-019: Public projection and immutable release model

Priority: P0

Size: L

Dependencies: BB-015, BB-017, BB-018

Deliver:

- Denormalized public projection tables.
- Immutable release records.
- Signed release manifests containing content hashes.
- Public JSON snapshots for entity pages.
- Search-index version associated with each release.
- Atomic release activation.
- Instant rollback to a prior release.
- Draft and preview release support.

Acceptance:

- Public pages never read draft canonical data.
- A release either activates completely or not at all.
- Rollback does not require rebuilding historical data.
- Public API responses include release and revision metadata.
- Unauthorized canonical changes cannot silently alter active public content.

BB-020: Backup, point-in-time recovery, and restore verification

Priority: P0

Size: M

Dependencies: BB-012, BB-019

Deliver:

- Automated Cloud SQL backups and point-in-time recovery.
- Export schedule for critical schemas.
- Separate retention for canonical, evidence, and audit data.
- Storage versioning where appropriate.
- Restore scripts.
- Quarterly restore test procedure.
- Recovery point and recovery time targets.

Acceptance:

- A staging environment can be restored from a production-compatible backup without exposing production secrets.
 - Restore verification checks row counts, hashes, constraints, and release manifests.
 - Backups cannot be deleted by ordinary runtime identities.
 - Recovery procedures are tested rather than assumed.
-

Epic C: Hostile-environment and abuse protection

BB-021: Separate public, submissions, internal, and admin surfaces

Priority: P0

Size: L

Dependencies: BB-005, BB-011, BB-012

Deliver:

- Public web on Firebase App Hosting.
- Public read API on Cloud Run.
- Submissions API on a separate Cloud Run service.
- Internal publication API inaccessible from the public internet.
- Admin application and API protected through IAP and application authorization.
- Distinct service accounts and deployment pipelines.

Acceptance:

- Submissions-service compromise cannot publish.
- Public API compromise cannot modify canonical data.
- Admin paths do not share public route handlers.
- Internal publication endpoints cannot be called using end-user tokens.

BB-022: Public App Hosting runtime hardening

Priority: P0

Size: M

Dependencies: BB-011, BB-019, BB-021

Deliver:

- Conservative `apphosting.yaml` CPU, memory, concurrency, and maximum-instance limits.
- Environment-specific limits.
- Static or cached rendering for public entity content.
- No database or model work during public page rendering.

- Strict cache keys.
- Query-string normalization.
- Response-size limits.
- Secure error pages and degraded mode.

Acceptance:

- Random query parameters do not force expensive regeneration.
- Public pages continue to render from release snapshots if APIs are disabled.
- Max-instance limits are validated after deployment.
- Server errors reveal no secrets or stack traces.

BB-023: Cloud Armor and protected public API ingress

Priority: P0

Size: L

Dependencies: BB-021

Deliver:

- Global external Application Load Balancer.
- Serverless network endpoint groups.
- Cloud Armor security policy.
- Rate-based bans and throttles.
- Preconfigured WAF rules where appropriate.
- Geographic controls only when evidence justifies them.
- Direct Cloud Run URLs disabled.
- Cloud CDN for cacheable API responses.

Acceptance:

- Internet traffic reaches APIs only through the load balancer.
- Direct `run.app` requests fail.
- Rate-limit behavior is load-tested.
- Denials and throttles produce metrics and alerts.
- Emergency deny rules can be activated without deploying code.

BB-024: Firebase App Check enforcement

Priority: P0

Size: M

Dependencies: BB-011, BB-021

Deliver:

- reCAPTCHA Enterprise App Check for web.
- Verification middleware for all public and submissions endpoints.

- Metrics-only rollout before enforcement.
- Debug-token handling restricted to local and test environments.
- Token replay protection where supported.
- Graceful error handling.

Acceptance:

- Invalid and missing App Check tokens are rejected after enforcement.
- Admin and internal service-to-service calls use appropriate trusted identities rather than browser App Check.
- App Check failures are observable without logging raw tokens.
- Debug tokens cannot work in production.

BB-025: Endpoint rate limits and abuse quotas

Priority: P0

Size: L

Dependencies: BB-023, BB-024

Deliver limits for:

- Search.
- Geocoding.
- Nearby discovery.
- Entity retrieval.
- Source inspection.
- Corrections.
- Authentication.
- Password reset.
- Administrative exports.
- Research starts.
- Publication preview generation.

Use layered controls:

- Cloud Armor IP or network throttles.
- App Check.
- Authenticated user quotas.
- Endpoint-specific token buckets.
- Device or session risk signals.
- Daily and rolling-window caps.
- Server-side concurrency limits.

Acceptance:

- Expensive endpoints have stricter limits than static reads.
- Anonymous users receive the smallest quota.
- Distributed abuse is detectable beyond a single IP.

- Rate-limit state cannot grow without bound.
- Users receive safe retry guidance without revealing thresholds useful to attackers.

BB-026: Search and query resource guardrails

Priority: P0

Size: L

Dependencies: BB-019, BB-025

Deliver:

- Minimum and maximum query length.
- Normalization and Unicode handling.
- Maximum filters, radius, date range, page size, and pagination depth.
- Cursor pagination.
- Query timeouts and database statement timeouts.
- Approved query shapes only.
- No user-provided SQL, sort expression, or field selection.
- Slow-query logging.
- Result caching and canonicalized cache keys.
- Export limits.

Acceptance:

- Pathological regular expressions and wildcard scans are impossible.
- Search cannot request arbitrary columns.
- Query cost remains bounded during fuzz and load tests.
- Database timeouts fail closed and do not exhaust the pool.

BB-027: Administrator identity and authorization

Priority: P0

Size: L

Dependencies: BB-011, BB-021

Deliver:

- Firebase Authentication for administrator identity.
- IAP in front of admin services.
- Required multi-factor authentication.
- Role and permission model using Firebase custom claims plus server-side database authorization.
- Reauthentication for publication, retraction, rights changes, policy changes, and privileged export.
- Session revocation.
- Administrative device and login alerts.

Acceptance:

- Client-side route checks are never the only authorization.
- Role changes take effect promptly.
- Disabled administrators lose active sessions.
- Sensitive actions require a reason and fresh authentication.
- No shared administrator account exists.

BB-028: Web application security controls**Priority:** P0**Size:** L**Dependencies:** BB-007, BB-021**Deliver:**

- Strict Content Security Policy.
- Trusted Types where practical.
- Secure, HTTP-only, same-site cookies.
- CSRF protection.
- Output encoding and HTML sanitization.
- Clickjacking protection.
- MIME sniffing protection.
- Referrer and permissions policies.
- Safe redirect handling.
- Canonical request size limits.
- Safe file and content disposition.
- Dependency-free sanitization where platform primitives suffice.

Acceptance:

- Stored and reflected XSS tests pass.
- Markdown or rich-text content cannot inject executable HTML.
- State-changing operations reject cross-site requests.
- Open redirects are impossible.
- Security headers are tested in CI and staging.

BB-029: Corrections and submission quarantine**Priority:** P0**Size:** L**Dependencies:** BB-015, BB-021, BB-025**Deliver:**

- Initial correction form limited to structured text and source URLs.
- No public file uploads in the initial beta.

- Separate `submission_inbox` and moderation states.
- Schema, size, character, link-count, and frequency validation.
- Spam scoring.
- Duplicate and coordinated-campaign detection.
- Immutable original payload plus normalized representation.
- Submitter privacy controls.
- Block and abuse-report tools.

Acceptance:

- Submissions cannot directly create or modify entities or claims.
- HTML, scripts, tracking pixels, and executable content are rejected.
- Repeated submissions do not create unbounded rows or work.
- Moderators can dismiss, merge, block, or convert a submission into a research case.
- Submitter identity is never shown publicly without explicit permission.

BB-030: Safe external URL handling and SSRF prevention

Priority: P0

Size: L

Dependencies: BB-004, BB-029

Deliver:

- Never fetch a submitted URL inside the submission request.
- Queue URL evaluation separately.
- Permit only HTTP and HTTPS.
- Resolve and reject private, loopback, link-local, metadata, multicast, and reserved destinations.
- Revalidate after every redirect.
- Limit redirect count, response bytes, content types, DNS behavior, and total duration.
- Egress-restricted fetch worker.
- Source-domain policy checks.
- Safe parser sandbox.
- Content hash and malware indicators.

Acceptance:

- Tests cover IPv4, IPv6, encoded IPs, DNS rebinding, redirects, user-info URLs, alternate schemes, and cloud metadata addresses.
- Fetch workers cannot reach production databases or internal APIs.
- Oversized and slow responses are terminated.
- A fetched page remains quarantined until validation completes.

BB-031: Future file-upload quarantine boundary

Priority: P1

Size: M

Dependencies: BB-005, BB-029

Deliver before enabling uploads:

- Separate quarantine bucket.
- Uniform bucket-level access.
- Object size and content-type allowlist.
- Random object names.
- No public read access.
- Malware scanning worker.
- Image and document re-encoding where appropriate.
- Metadata stripping.
- Human approval before movement to private evidence or public media.
- Retention and deletion policy.

Acceptance:

- Uploads remain disabled until every control is complete.
- Original files are never rendered inline to administrators.
- Scanning failures quarantine rather than approve.
- Public buckets accept objects only from the publication service.

BB-032: Data-poisoning and promotion controls

Priority: P0

Size: L

Dependencies: BB-017, BB-018, BB-019, BB-029

Deliver:

- Explicit pipeline from submission or discovery to research case, proposed claim, accepted claim, publication candidate, and release.
- Source-reputation and independence checks.
- Claim-level corroboration.
- Contradiction search requirement.
- Duplicate and coordinated-source detection.
- Review queues based on impact and confidence.
- Separation of proposer and deterministic approver.
- Promotion transaction with audit event.
- Release preview and diff.

Acceptance:

- A large number of submissions cannot increase confidence by volume alone.
- Multiple pages copied from one source count as one lineage.
- A source cannot approve claims about itself solely through repetition.
- High-impact claims cannot publish without their stronger evidence requirements.
- Publication preview shows added, changed, and removed claims.

BB-033: Cost and resource exhaustion controls**Priority:** P0**Size:** L**Dependencies:** BB-022, BB-023, BB-025**Deliver:**

- Conservative maximum instances for every Cloud Run and App Hosting backend.
- Cloud Tasks queue rate and concurrency limits.
- Per-job CPU, memory, duration, and retry limits.
- Database connection and statement limits.
- Daily geocoder, model, OCR, and source budgets.
- Research campaign budgets.
- Billing exports and anomaly alerts.
- Automated soft shutdowns for optional workloads.
- Manual hard-stop runbook.
- No automatic disabling of the public historical corpus unless explicitly chosen.

Acceptance:

- A traffic spike cannot scale every service without bound.
- Retries have capped exponential backoff and maximum attempts.
- Optional research stops before public serving.
- Budget alerts are paired with concrete automated responses.
- Cost-control tests simulate an abusive traffic pattern.

BB-034: Security telemetry and anomaly detection**Priority:** P0**Size:** L**Dependencies:** BB-018, BB-023, BB-024, BB-025**Deliver dashboards and alerts for:**

- Cloud Armor denies and throttles.
- App Check failures.
- Authentication failures.
- Administrator role changes.

- Submission spikes.
- Search and geocoder abuse.
- Database connections and slow queries.
- Queue depth and retries.
- Source adapter anomalies.
- Publication and retraction activity.
- Unexpected public-schema writes.
- Storage access denials.
- Error rates and latency.
- Cost anomalies.

Acceptance:

- Alerts include severity, runbook, release, service, and correlation identifiers.
- Logs exclude secrets and protected addresses.
- Metrics are useful before launch through synthetic tests.
- High-severity publication and administrator events generate immediate notification.

BB-035: Incident response and kill switches

Priority: P0

Size: L

Dependencies: BB-019, BB-033

Deliver kill switches for:

- Corrections and submissions.
- Search.
- Geocoding.
- Nearby location use.
- Individual source adapters.
- Research campaigns.
- LLM calls.
- File uploads.
- Publication.
- Administrative exports.

Deliver runbooks for:

- DDoS or bot flood.
- Account compromise.
- Secret leak.
- Data poisoning.
- Unauthorized publication.
- Defacement.
- Database compromise.
- Cloud bill spike.
- Malicious source.

- Privacy incident.
- Dependency compromise.

Acceptance:

- Public site can enter read-only static mode without a deployment.
- Active release can roll back immediately.
- Service credentials can be revoked independently.
- Queue processing can be paused without dropping tasks.
- A tabletop incident exercise validates the controls.

BB-036: Security testing and CI gates

Priority: P0

Size: L

Dependencies: BB-008, BB-009, BB-028, BB-030

Deliver:

- CodeQL or equivalent code scanning.
- Dependency review.
- Secret scanning.
- Software-bill-of-materials generation.
- Container vulnerability scanning.
- Infrastructure policy checks.
- API authorization tests.
- OWASP ASVS-based test checklist.
- OWASP API abuse tests.
- DAST against staging.
- SSRF, XSS, CSRF, BOLA, mass-assignment, and resource-consumption tests.
- Release-signature validation.

Acceptance:

- High-severity findings block production.
- Suppressions require reason, owner, and expiration.
- Staging security scans use isolated test identities.
- Security artifacts are retained with the release.
- Production deployment records the exact tested commit and image digest.

Epic D: Deterministic research and evidence pipeline

BB-037: Source registry and adapter contract

Priority: P0

Size: L

Dependencies: BB-016, BB-018

Deliver:

- Source registry UI and API.
- Adapter interface declaring identity, rights, permitted claims, refresh schedule, rate limits, expected volume, geographic coverage, parser version, and kill switch.
- Fixture-based parser tests.
- Canary mode.
- Parser drift metrics.
- Dead-letter and quarantine states.

Acceptance:

- No adapter runs without an approved source policy.
- Unexpected record-count or schema changes quarantine the run.
- Adapter output validates against shared schemas.
- Every candidate retains source and parser provenance.

BB-038: Versioned historical query packs

Priority: P0

Size: M

Dependencies: BB-003, BB-037

Deliver:

- Versioned query packs by entity type and theme.
- Positive, negative, historical, modern, geographic, alias, and source-specific terms.
- Offensive historical terminology stored only where research requires it.
- Test fixtures showing expected matches and exclusions.
- Query-pack effectiveness metrics.

Acceptance:

- Query-pack changes are reviewable and versioned.
- Weak signals produce candidates only.
- Public interfaces do not expose offensive historical terms as default language.

- Every discovery run records the query-pack version.

BB-039: Candidate discovery pipeline

Priority: P0

Size: L

Dependencies: BB-037, BB-038

Deliver:

- Bulk and API candidate ingestion.
- Content hashing.
- Candidate identity and source references.
- Basic geographic extraction.
- Strong, medium, and weak signal extraction.
- Deduplication.
- Retry, quarantine, and dead-letter handling.
- Campaign boundaries and budgets.

Acceptance:

- Discovery never creates a public entity.
- Duplicate source records merge without losing provenance.
- Failed candidates do not block the full campaign.
- Campaign output is reproducible from source version and query-pack version.

BB-040: Deterministic relevance engine

Priority: P0

Size: L

Dependencies: BB-003, BB-039

Deliver:

- Relevance gates.
- Scoring dimensions and thresholds.
- Inclusion, exclusion, and supporting-context decisions.
- Human-readable “Why this appears” reason.
- Feature-value storage.
- Policy-version storage.
- Manual override with required reason.
- Distinctiveness and duplication checks.

Acceptance:

- Accurate but irrelevant candidates can be excluded.
- Weak signals cannot independently pass relevance.

- Every included candidate has supporting evidence for relevance itself.
- Public numeric relevance scores remain hidden.
- Gold fixtures pass expected decisions.

BB-041: Entity and historical-location resolution

Priority: P0

Size: L

Dependencies: BB-014, BB-039

Deliver:

- Alias normalization.
- Exact and fuzzy name matching.
- Address parsing.
- Temporal consistency checks.
- Geographic consistency checks.
- School-name history.
- Organization and person disambiguation.
- Duplicate review queue.
- Match confidence and rationale.
- Historic and current boundary handling.

Acceptance:

- Candidates are not merged solely because names match.
- Historical addresses are evaluated against applicable time periods.
- Ambiguous matches remain unresolved rather than forced.
- Merge and split operations preserve full lineage.

BB-042: Atomic claim extraction and evidence registration

Priority: P0

Size: L

Dependencies: BB-016, BB-017, BB-041

Deliver:

- Deterministic parsers and manual claim-entry tools.
- Atomic claim schema validation.
- Evidence-span registration.
- Quotation accuracy.
- Temporal and geographic context.
- Legal procedural-status validation.
- Contradiction recording.
- Unsupported-claim rejection.

Acceptance:

- One claim expresses one independently supportable assertion.
- Exact quotations require exact evidence location.
- A claim cannot become accepted without qualifying evidence.
- Extraction uncertainty is stored rather than omitted.

BB-043: Confidence and source-lineage engine

Priority: P0

Size: L

Dependencies: BB-017, BB-042

Deliver:

- Deterministic evidence confidence.
- Source authority and directness.
- Lineage independence.
- Temporal proximity.
- Geographic precision.
- Entity-match quality.
- Extraction quality.
- Contradiction penalty.
- Threshold evaluation.
- Calibration dataset export.

Acceptance:

- Five syndicated copies do not count as five independent sources.
- Confidence recalculates when source, evidence, contradiction, or policy changes.
- Public language cannot be stronger than evidence procedural status.
- Score and component versions remain auditable.

BB-044: Research-case and publication workflow

Priority: P0

Size: L

Dependencies: BB-040, BB-041, BB-042, BB-043

Deliver workflow states for:

- Candidate.
- Relevance review.
- Relevance confirmed.
- Minimum record.
- Partial enrichment.
- Substantial enrichment.

- Insufficient evidence.
- Excluded.
- Merged.
- Retracted.

Provide:

- Review queues.
- Assignment.
- Reason codes.
- Evidence checklist.
- Preview.
- Promotion.
- Retraction.
- Backfill scheduling.

Acceptance:

- Sparse records can publish when minimum requirements are met.
- Excluded records retain the reason and can be reconsidered after new evidence.
- Retraction removes content through a new release rather than erasing history.
- Workflow permissions are enforced server-side.

BB-045: Wikimedia discovery adapter

Priority: P1

Size: L

Dependencies: BB-037, BB-038, BB-039

Deliver:

- MediaWiki search and category traversal.
- Wikidata identifiers and relationships.
- Alias and location extraction.
- External-reference routing.
- Curated category graph.
- Bulk-processing path rather than high-volume public SPARQL dependence.
- Attribution metadata where reuse applies.

Acceptance:

- Category membership is never automatic inclusion.
- Wikipedia prose is not copied into Black Book by default.
- Candidate records retain page revision and external identifiers.
- Bulk and API modes produce the same normalized contract.

BB-046: Federal archive and public-history adapters

Priority: P1

Size: L

Dependencies: BB-037, BB-039

Deliver initial adapters for:

- Library of Congress.
- National Archives.
- DPLA.
- National Park Service and National Register materials.
- Approved structured school-history sources.

Acceptance:

- Each adapter has independent fixtures, rights rules, rate limits, and kill switch.
- Large exports are filtered outside the canonical application database.
- Only qualifying candidate metadata and evidence are retained.
- Adapter failure cannot affect public serving.

BB-047: Gold corpus and calibration harness

Priority: P0

Size: L

Dependencies: BB-040, BB-041, BB-043, BB-044

Deliver:

- At least 100 to 200 adjudicated examples.
- Included and excluded schools.
- Relevant and irrelevant people.
- Disputed claims.
- High-impact claims.
- Sparse records.
- Living people.
- Private residences.
- Sundown-town candidates.
- Geographic ambiguity.
- Source-lineage examples.

Acceptance:

- Corpus is versioned.
- Precision, recall, false-publication rate, calibration, citation entailment, and entity-resolution accuracy can be measured.
- Policy or algorithm changes generate before-and-after reports.

- No automatic publication feature ships without corpus evaluation.
-

Epic E: Public and administrative product

BB-048: Public application shell and navigation

Priority: P0

Size: L

Dependencies: BB-007, BB-019, BB-022

Deliver:

- Home page.
- Search entry.
- Location discovery entry.
- Topic navigation.
- Featured stories.
- Methodology and transparency.
- About and correction routes.
- Responsive application shell.
- Error, empty, loading, offline, and degraded states.

Acceptance:

- Public shell renders without authentication.
- Core pages remain usable with JavaScript disabled where practical.
- Site clearly explains what qualifies for Black Book.
- Design is recognizably Black Book, not a generic dashboard.

BB-049: Search API and experience

Priority: P0

Size: L

Dependencies: BB-019, BB-025, BB-026, BB-048

Deliver:

- Search by person, institution, school, place, event, neighborhood, city, county, state, and ZIP input.
- Alias and misspelling support.
- Facets by entity type, theme, geography, period, record maturity, and research coverage.
- Cursor pagination.
- Search explanations and matched-name display.
- No protected-address matching.

Acceptance:

- Results are ranked by relevance and connection strength, not fame alone.
- Search remains bounded under adversarial input.
- Sparse records are discoverable.
- Search results indicate why each item is connected to the place or query.

BB-050: U.S. address and current-location discovery

Priority: P0

Size: L

Dependencies: BB-015, BB-025, BB-049

Deliver:

- U.S. Census Geocoder adapter.
- Address normalization.
- ZIP-to-place translation.
- Municipality, county, neighborhood, institution, and historical-geography matching.
- Browser location permission flow.
- Explicit user action before location access.
- Geocode cache.
- Coarse analytics only.
- No persistent precise-location history.

Acceptance:

- Territory results are handled according to the 50 states plus D.C. product scope.
- Address searches are not stored as user history by default.
- Exact coordinates are reduced when no longer needed.
- Geocoder failure provides manual place search.
- Requests are rate-limited and cached.

BB-051: Results list and map

Priority: P1

Size: L

Dependencies: BB-049, BB-050

Deliver:

- Accessible result list as the primary experience.
- Map as an enhancement.
- Provider abstraction.
- Clustering and bounded result sets.
- Historical and current boundary differentiation.
- Precision-aware markers.

- Map/list synchronization.
- No living-residence markers.

Acceptance:

- Every map result is also usable through the list.
- Marker precision follows public precision policy.
- Map requests cannot retrieve an unbounded national dataset.
- Keyboard and screen-reader users can explore all results.

BB-052: Entity, place, school, event, and institution pages

Priority: P0

Size: L

Dependencies: BB-019, BB-048, BB-049

Deliver:

- Shared entity layout with type-specific sections.
- Concise relevance explanation.
- Historical context.
- Accepted claims.
- Related people, places, institutions, events, and sources.
- Timelines.
- Location precision notices.
- Record maturity and research coverage.
- Revision metadata.

Acceptance:

- Every factual statement maps to a claim.
- Sparse records use approved missing-information language.
- Pages distinguish historical from present-day facts.
- No page becomes a generic biography unrelated to place or Black history.

BB-053: Evidence, confidence, dispute, and revision interface

Priority: P0

Size: L

Dependencies: BB-017, BB-019, BB-052

Deliver:

- Evidence confidence cards.
- Research coverage.
- Source lineage count.
- Claim-by-claim sources.

- Evidence excerpts within rights limits.
- Contradiction and dispute presentation.
- Last checked date.
- Policy and revision history.
- Retraction and correction notices.

Acceptance:

- Confidence is labeled as an evidence score rather than a probability unless calibrated.
- Users can distinguish confidence, relevance, connection strength, and research coverage.
- Disagreement is visible rather than silently resolved.
- Source links do not leak private evidence or protected information.

BB-054: “Why this appears” and balanced historical storytelling

Priority: P0

Size: M

Dependencies: BB-003, BB-040, BB-052

Deliver:

- Public relevance explanation.
- Story composition rules balancing harm, achievement, joy, family, community, institution-building, resistance, culture, and everyday life.
- Editorial checks against passive euphemisms.
- Trauma-content notices where warranted.
- Missing-perspective indicators.

Acceptance:

- Every entity explains its substantive connection.
- A Black person’s race, fame, attendance, employment, or residence alone is never presented as the reason.
- Results do not collapse Black history into violence-only content.
- Explanations derive from accepted relevance evidence.

BB-055: Correction and challenge experience

Priority: P0

Size: L

Dependencies: BB-029, BB-032, BB-052

Deliver:

- Correction form tied to entity, claim, source, or location.
- Structured categories.
- Source URL support.

- Privacy notice.
- Submission receipt code.
- Status page that reveals no moderation-sensitive information.
- Abuse reporting.
- Appeal workflow for rejections or disputed classifications.

Acceptance:

- Corrections enter quarantine.
- Anonymous correction volume is tightly limited.
- Coordinated brigading does not alter confidence or publication.
- Submitters cannot enumerate other submissions.
- Administrators can convert a correction into a research case.

BB-056: Administration and research console

Priority: P0

Size: XL

Dependencies: BB-027, BB-037, BB-044

Deliver:

- Candidate queue.
- Relevance review.
- Entity resolution.
- Source registry and adapter status.
- Research cases.
- Claims, evidence, contradictions, and confidence.
- Submission moderation.
- Publication preview and release.
- Retraction and rollback.
- Audit explorer.
- Security and operational dashboards.
- Feature and kill switches.

Acceptance:

- Permissions restrict every action.
- High-impact actions require fresh authentication and reason.
- Console never directly edits active public projections.
- Every change shows its resulting publication diff.
- Bulk actions have preview, limits, and rollback.

BB-057: Accessibility, SEO, performance, and privacy review

Priority: P0

Size: L

Dependencies: BB-048 through BB-056

Deliver:

- Automated and manual accessibility testing.
- Semantic headings and landmarks.
- Keyboard navigation.
- Screen-reader labels.
- Structured metadata.
- Canonical URLs.
- Sitemaps derived from active releases.
- Performance budgets.
- Image optimization.
- Minimal analytics.
- Consent-aware telemetry.
- No behavioral advertising.

Acceptance:

- Core journeys pass accessibility review.
 - Search and map have accessible alternatives.
 - No protected information appears in metadata or previews.
 - Performance regression budgets block release.
 - Public pages remain stable during API degraded mode.
-

Epic F: Seed, resilience validation, and beta release

BB-058: Initial high-confidence national seed

Priority: P1

Size: XL

Dependencies: BB-044 through BB-047, BB-052

Deliver seed campaigns for:

- Rosenwald schools.
- Freedmen's schools.
- Historically Black schools.
- Schools in consequential desegregation litigation.
- Institutions central to documented Black educational movements.

- Selected nationally or regionally significant Black institutions.
- A geographically diverse sample.

Acceptance:

- Quality determines count.
- Every public record passes relevance and evidence gates.
- Sparse but verified records are allowed.
- Seed does not import all U.S. schools.
- Geographic and thematic gaps are documented.

BB-059: Load, abuse, and cost testing

Priority: P0

Size: L

Dependencies: BB-023 through BB-026, BB-033, BB-049

Deliver test scenarios for:

- High-volume static traffic.
- Search floods.
- Cache-busting attempts.
- Geocoder abuse.
- Submission spam.
- Slow clients.
- Oversized payloads.
- Distributed low-rate attacks.
- Database connection exhaustion.
- Queue retry storms.
- Expensive filter combinations.
- Scraping patterns.

Acceptance:

- Services remain within configured resource caps.
- Public static content remains available when expensive features throttle.
- Cost per abusive request is understood.
- Tests prove that rate limits do not depend on one control alone.
- Results create concrete tuning changes.

BB-060: Adversarial integrity exercise

Priority: P0

Size: L

Dependencies: BB-032, BB-043, BB-044, BB-055

Deliver red-team scenarios for:

- False source submissions.
- Source laundering.
- Coordinated citation repetition.
- Altered documents.
- Misidentified people.
- Living-address attempts.
- Procedural-status inflation.
- Race inference.
- Relevance gaming.
- Moderator social engineering.
- Unauthorized publication.

Acceptance:

- False submissions cannot directly change public content.
- Lineage detection prevents volume-based confidence inflation.
- High-impact language remains constrained.
- Every discovered gap becomes a test and remediation bead.

BB-061: Recovery and rollback rehearsal

Priority: P0

Size: M

Dependencies: BB-020, BB-035

Deliver rehearsal for:

- Database restore.
- Active-release rollback.
- Revoking compromised deploy identity.
- Rotating secrets.
- Pausing queues.
- Disabling submissions.
- Blocking malicious traffic.
- Rebuilding public projections.
- Restoring a deleted public object.

Acceptance:

- Measured recovery times are recorded.
- Procedures can be followed by one developer under pressure.
- Critical recovery does not require access to the compromised service.
- Findings update runbooks and infrastructure.

BB-062: Production release pipeline

Priority: P0

Size: L

Dependencies: BB-010, BB-020, BB-036, BB-057

Deliver GitHub Actions workflows for:

- Pull-request validation.
- Firebase preview environments where appropriate.
- Staging deployment.
- Database migration.
- API and admin deployment.
- App Hosting rollout trigger.
- Security scans.
- End-to-end smoke tests.
- Production approval.
- Progressive release.
- Automatic rollback on failed health checks.
- Release provenance and changelog.

Acceptance:

- Automatic App Hosting rollouts are disabled.
- GitHub Actions deploys only the tested commit.
- Production requires a protected environment approval.
- Migrations are completed safely before incompatible code receives traffic.
- Rollback procedure is tested.

BB-063: Beta launch gate

Priority: P0

Size: M

Dependencies: BB-047, BB-058 through BB-062

Required launch conditions:

- Published claims with evidence: 100%.
- Unsupported narrative statements: 0.
- Living residential addresses displayed: 0.
- Untracked publication decisions: 0.
- Source-policy violations: 0.
- High-impact claim precision target met on the gold corpus.
- Restore rehearsal complete.
- Incident exercise complete.
- Load and abuse limits verified.
- Public methodology and correction process available.

- Legal and privacy review issues tracked.

Acceptance:

- Launch decision is recorded against measurable evidence.
 - Failed gates block launch rather than becoming informal follow-ups.
 - Public beta can be disabled or returned to static read-only mode quickly.
-

Epic G: Deliberately deferred capabilities

BB-064: LLM provider and research-mode framework

Priority: P2

Size: L

Dependencies: BB-042, BB-043, BB-044, BB-063

Deliver only after deterministic beta:

- Off, manual, assist, scheduled, campaign, summary-only, and research-only modes.
- Provider abstraction.
- Structured evidence-package output.
- Per-provider and per-campaign budgets.
- Model-call audit.
- Accepted-claim-only narrative generation.
- No model self-approval.

Acceptance:

- System works fully with LLM mode off.
- Model output is always treated as proposed untrusted data.
- Narrative validator rejects unsupported sentences.
- Model use cannot bypass confidence or publication policy.

BB-065: Prompt-injection and model-tool isolation

Priority: P2

Size: L

Dependencies: BB-030, BB-064

Deliver:

- Treat source documents as untrusted data.
- No unrestricted browsing, shell, database, publication, or secret access from research prompts.
- Tool allowlists.
- Typed input and output.

- Citation validation.
- Content-boundary markers.
- Adversarial document fixtures.
- Maximum tokens, cost, depth, retries, and wall-clock duration.
- Model-output quarantine.

Acceptance:

- A document cannot cause the model to publish, contact third parties, retrieve secrets, or change policy.
- Tool calls are independently authorized by deterministic code.
- Prompt-injection tests run in CI for research components.

BB-066: Mobile-ready shared contracts

Priority: P2

Size: M

Dependencies: BB-049 through BB-053

Deliver:

- Framework-independent domain schemas.
- Versioned API contracts.
- Shared authentication and App Check assumptions.
- Cursor pagination.
- Offline-safe public release snapshots.
- Deep-link identifiers.
- Location-privacy contracts.
- Audio and walking-tour extension points.

Acceptance:

- Web code does not leak Next.js-specific types into API contracts.
- Future Expo clients can consume public APIs without redesigning the domain model.
- No mobile application is built in this bead.

Recommended execution sequence

Tranche 1: Secure foundation

BB-001
BB-002
BB-003
BB-004

BB-005
BB-006
BB-008
BB-009
BB-010

Tranche 2: Data and publication boundary

BB-011
BB-012
BB-013
BB-014
BB-015
BB-016
BB-017
BB-018
BB-019
BB-020

Tranche 3: Hostile-environment protection

BB-021
BB-022
BB-023
BB-024
BB-025
BB-026
BB-027
BB-028
BB-029
BB-030
BB-032
BB-033
BB-034
BB-035
BB-036

Tranche 4: Research and evidence engine

BB-037
BB-038
BB-039
BB-040

BB-041
BB-042
BB-043
BB-044
BB-047

Tranche 5: Public beta product

BB-048
BB-049
BB-050
BB-052
BB-053
BB-054
BB-055
BB-056
BB-057

Tranche 6: Seed and launch

BB-045
BB-046
BB-058
BB-059
BB-060
BB-061
BB-062
BB-063

Deferred

BB-031
BB-051
BB-064
BB-065
BB-066